

MARCO INTEGRATIVO GQM+ PRAGMATIC

Metodología de Trazabilidad desde Objetivos Nacionales a Métricas de Ciberseguridad

TABLA DE CONTENIDOS

1. Introducción a GQM+ PRAGMATIC
2. Estructura Jerárquica GQM (3 niveles)
3. Los 9 Criterios PRAGMATIC Explicados
4. Matriz de Integración GQM + PRAGMATIC
5. Aplicación a Ciberseguridad España (Mercury AVRQ)
6. Ciclo de Medición Completo
7. Validación y Evolución de Métricas

1. INTRODUCCIÓN A GQM+ PRAGMATIC

1.1 ¿Qué es GQM (Goal-Question-Metric)?

GQM es un enfoque jerárquico desarrollado por Victor Basili (NASA) para establecer trazabilidad completa desde objetivos estratégicos hasta datos cuantitativos medibles.

Estructura fundamental:

NIVEL CONCEPTUAL:	Objetivo estratégico (Goal)
	↓
NIVEL OPERACIONAL:	Preguntas que lo operacionalizan (Question)
	↓
NIVEL CUANTITATIVO:	Métricas que responden las preguntas (Metric)

Ventaja GQM vs. metrología tradicional:

- Tradicional: "Midamos esto" → (¿Por qué?) → (¿Qué hacemos con los datos?)
- GQM: "¿Cuál es nuestro objetivo?" → "¿Qué preguntas lo miden?" → "¿Qué métricas responden?"

1.2 ¿Qué es PRAGMATIC (Criteria)?

PRAGMATIC es un conjunto de 9 criterios para evaluar si una métrica es útil en el mundo real (no solo académica).

Sigla desagregada:

- **Predictive** (¿Predice resultados futuros?)
- **Relevant** (¿Importa a stakeholders?)
- **Actionable** (¿Se puede actuar sobre ella?)
- **Genuine** (¿Es auténtica, no artificial?)
- **Meaningful / Significant** (¿Es estadísticamente significativa?)
- **Accurate / Precise** (¿Tiene precisión técnica?)
- **Timely / Oportuno** (¿Se obtiene a tiempo para tomar decisiones?)

- Independent (¿No depende de factores externos?)
- Cost-effective (¿El costo de medición es razonable?)

1.3 ¿Por Qué Integrar GQM + PRAGMATIC?

GQM soluciona el problema: "¿Estamos midiendo lo correcto?"

PRAGMATIC soluciona el problema: "¿Es esta métrica útil realmente?"

Juntas solucionan: "¿Estamos midiendo lo correcto de forma útil?"

2. ESTRUCTURA JERÁRQUICA GQM (3 NIVELES)

2.1 Nivel 1: GOAL (Objetivo)

Definición:

Un objetivo estratégico aplicado a un objeto, desde una perspectiva particular, en un contexto específico.

Estructura formal:

GOAL :

- Para: [Organización/Stakeholder]
- Objeto: [Qué se mide]
- Propósito: [Qué se logra]
- Perspectiva: [Desde qué punto de vista]
- Contexto: [En qué entorno/restricciones]

Ejemplo Goal en Ciberseguridad:

GOAL: Asegurar que España cumple NIS2 antes de Q1 2026

Desglosado:

- Para: Gobierno español, regulador CNCS
- Objeto: Conformidad normativa de Entidades Esenciales/Importantes
- Propósito: Evitar multas, establecer postura defensible
- Perspectiva: Auditoría regulatoria (CNCS)
- Contexto: Transposición de Directiva EU 2022/2555

2.2 Nivel 2: QUESTION (Pregunta)

Definición:

Preguntas operacionales que desglosan el objetivo en aspectos medibles.

Una pregunta responde: "¿Cómo sabremos si hemos logrado este objetivo?"

Características:

- Específica (no ambigua)
- Responsable con datos
- Orientada a decisión

Ejemplo Questions para Goal NIS2:

Q1: ¿Cuáles son las medidas técnicas y organizacionales obligatorias?
Q2: ¿Qué porcentaje de cada medida está implementado actualmente?
Q3: ¿En qué plazo podemos alcanzar 100% conformidad?
Q4: ¿Qué recursos (presupuesto, personal) se requieren?
Q5: ¿Cuál es el riesgo residual si no cumplimos?

2.3 Nivel 3: METRIC (Métrica)

Definición:

Dato o conjunto de datos que responden las preguntas cuantitativamente.

Características:

- Observable (se puede medir)
- Cuantificable (número/%, rango)
- Repeatable (se puede replicar)
- Relacionado directamente a una pregunta

Ejemplo Metrics para Questions:

Q1 → M1: Listado de 21 medidas NIS2 obligatorias (documento)
Q2 → M2: Porcentaje de conformidad por medida (0-100%)
Q3 → M3: Roadmap con hitos y fechas (plan)
Q4 → M4: Presupuesto requerido en euros, FTE en personas
Q5 → M5: AVRQ Score de riesgo residual (0-1.0)

3. LOS 9 CRITERIOS PRAGMATIC EXPLICADOS

3.1 P = Predictive (Predictivo)

Definición:

¿La métrica predice o correlaciona con resultados futuros de importancia?

Preguntas de validación:

- ¿Cambios en esta métrica indican cambios en postura de seguridad futura?
- ¿Puedo proyectar resultados del control de seguridad basado en este indicador?
- ¿Es un KPI leading indicator (indicador principal) o lagging (rezagado)?

Escala (1-5):

1 = No predice nada; puramente retrospectivo
2 = Débil correlación con resultados futuros
3 = Correlación moderada; algunos casos predice bien
4 = Fuerte correlación; predice resultados en mayoría casos
5 = Altamente predictivo; demuestra causación

Ejemplo - Métrica SIEM:

✗ Métrica débil (P=1): "Número de alertas totales SIEM mensualmente"
(¿Importa si tienes 10K alertas o 100K si la mayoría son falsos positivos?)

 **Métrica fuerte (P=5):** "Tasa de verdaderos positivos SIEM × MTTD"
(Predice si detectarás amenazas reales antes que causen daño)

3.2 R = Relevant (Relevante)

Definición:

¿La métrica importa a stakeholders clave (ejecutivos, reguladores, equipo)?

Preguntas de validación:

- ¿Es importante para la Junta Directiva?
- ¿Es importante para regulador (CNCS, AEPD)?
- ¿Es importante para el equipo de seguridad?
- ¿Está vinculada a decisiones de negocio real?

Escala (1-5):

- 1 = Completamente irrelevante; nadie la entiende o importa
- 2 = Marginal; solo interesa a especialistas técnicos
- 3 = Moderadamente relevante; importa a algunos stakeholders
- 4 = Muy relevante; importa a múltiples stakeholders
- 5 = Crítica; es central a decisiones estratégicas

Ejemplo - Métrica Vulnerabilidades:

 **Métrica débil (R=1):** "Número de vulnerabilidades descubiertas por método de escaneo X"
(¿Qué hace la ejecutiva con esto?)

 **Métrica fuerte (R=5):** "% de vulnerabilidades críticas remediadas en <14 días (requisito NIS2)"
(Relevante para: CFO (costo), CISO (cumplimiento), Junta (riesgo legal))

3.3 A = Actionable (Accionable)

Definición:

¿Podemos tomar una acción específica basada en los resultados?

Preguntas de validación:

- Si el valor sube/baja, ¿qué acción disparamos?
- ¿Es clara la interpretación (qué significa "bueno" vs "malo")?
- ¿Podemos asignar responsables a mejorar esta métrica?
- ¿Se vincula directamente a un control o proceso?

Escala (1-5):

- 1 = Ambigua; no está claro qué hacer si el valor cambia
- 2 = Débilmente accionable; acciones posibles pero no evidentes
- 3 = Accionable con interpretación; requiere análisis para entender
- 4 = Muy accionable; interpretación clara, acciones obvias
- 5 = Totalmente accionable; métrica dispara acciones automáticas

Ejemplo - Métrica Capacitación:

✗ Métrica débil (A=1): "Número de empleados que completaron capacitación"

(¿Qué hago si 500 completaron vs 600? ¿Más o menos es mejor?)

**✓ Métrica fuerte (A=5): "% de empleados con evaluación de conocimiento >80%, disparando
escalada de capacitación para <80%"**

(Acción clara: if %<80% → capacitación reforzada para ese grupo)

3.4 G = Genuine (Genuino)

Definición:

¿La métrica refleja realidad, no es gaming/manipulada?

Preguntas de validación:

- ¿Es difícil "jugar" con esta métrica sin mejorar realmente?
- ¿Está protegida de incentivos perversos?
- ¿La recolección de datos es transparente?
- ¿Es posible manipular la métrica sin mejorar seguridad?

Escala (1-5):

- 1 = Fácil gaming; métrica manipulable sin mejorar seguridad
- 2 = Vulnerable a gaming en ciertos casos
- 3 = Moderadamente protegida; some gaming posible
- 4 = Bien protegida; gaming requeriría esfuerzo real
- 5 = A prueba de gaming; cualquier manipulación requiere mejoría real

Ejemplo - Métrica Parches:

✗ Métrica débil (G=1): "Número de parches aplicados"

(Fácil gaming: aplicar parches innecesarios para inflar número)

**✓ Métrica fuerte (G=5): "% de sistemas críticos con parches de seguridad crítica en <7 días, auditado
por tercero independiente"**

(Gaming = Mejora real)

3.5 M = Meaningful / Significant (Significativo)

Definición:

¿La métrica es estadísticamente significativa y no trivial?

Preguntas de validación:

- ¿El tamaño del efecto es importante?
- ¿O es tan pequeño que es ruido?
- ¿La varianza es natural o refleja cambio real?
- ¿Está suficientemente desagregada (no solo "agregado")?

Escala (1-5):

1 = Trivial; cambios observados probablemente ruido
2 = Escasamente significativo; cambios <5%
3 = Moderadamente significativo; cambios 5-10%
4 = Significativo; cambios >10% detectables
5 = Altamente significativo; cambios <1% detectables

Ejemplo - Métrica Incidentes:

 **Métrica débil (M=1):** "¿Tuvimos un incidente este trimestre?" (Sí/No)
(Cambio binario, trivial)

 **Métrica fuerte (M=5):** "MTTR de incidentes críticos: X horas ± Y% CI 95%"
(Cambios de 1 hora son estadísticamente detectables)

3.6 A = Accurate / Precise (Preciso)

Definición:

¿La métrica se recolecta con precisión técnica?

Preguntas de validación:

- ¿Cuál es el error de medición?
- ¿Es automática o manual? (manual = más error)
- ¿Está definida sin ambigüedad?
- ¿Se valida regularmente?

Escala (1-5):

1 = Muy imprecisa; error >50%
2 = Imprecisa; error 20-50%
3 = Moderadamente precisa; error 5-20%
4 = Precisa; error <5%
5 = Altamente precisa; error <1%

Ejemplo - Métrica CVSS:

 **Métrica débil (A=1):** "Vulnerabilidades manuales puntuadas por analista"
(Subjetivo, inconsistente, error ~40%)

 **Métrica fuerte (A=5):** "CVSS v3.1 automático con NVD + validación de scanner"
(Estandarizado, consistente, error <1%)

3.7 T = Timely / Oportuno (Oportuno)

Definición:

¿Se obtiene el dato a tiempo para tomar decisiones?

Preguntas de validación:

- ¿Cuánto tarda en disponible? (minutos, horas, días, meses?)
- ¿Es tiempo suficiente para actuar?

- ¿O es retroactivo?
- ¿Se puede monitorear en tiempo real?

Escala (1-5):

- 1 = Muy tardío; disponible después decisiones ya tomadas
- 2 = Tardío; disponible con semanas/meses de retraso
- 3 = Moderadamente oportuno; disponible en días
- 4 = Oportuno; disponible en horas
- 5 = Muy oportuno; disponible en tiempo real (<5 min)

Ejemplo - Métrica Detección:

 **Métrica débil (T=1):** "Incidentes detectados en auditoría trimestral"
(3 meses de retraso)

 **Métrica fuerte (T=5):** "MTTD de amenazas críticas: <1 hora, automático SIEM"
(Tiempo real para actuar)

3.8 I = Independent (Independiente)

Definición:

¿La métrica está bajo nuestro control directo? ¿O depende de factores externos?

Preguntas de validación:

- ¿Qué % del resultado está bajo nuestro control?
- ¿Hay variables externas que distorsionan?
- ¿Podemos aislar el efecto de nuestras acciones?

Escala (1-5):

- 1 = Muy dependiente; <20% bajo nuestro control
- 2 = Dependiente; 20-40% bajo nuestro control
- 3 = Moderadamente independiente; 40-60% bajo control
- 4 = Muy independiente; 60-80% bajo control
- 5 = Completamente independiente; >80% bajo control

Ejemplo - Métrica Seguridad de Proveedores:

 **Métrica débil (I=1):** "% de brechas en proveedores nuestros"
(Bajo nuestro control: ¿10%? Depende proveedor)

 **Métrica fuerte (I=5):** "% de nuestros contratos con cláusulas de seguridad implementadas"
(100% bajo nuestro control)

3.9 C = Cost-effective (Rentable)

Definición:

¿El costo de recolectar/analizar la métrica es razonable vs. valor obtenido?

Preguntas de validación:

- ¿Cuánto cuesta recolectar (tiempo, herramientas)?
- ¿Es proporcional al valor de información?
- ¿Hay alternativas más económicas?
- ¿Se automatiza fácilmente?

Escala (1-5):

- 1 = Muy caro; costo > 10x el valor de información
- 2 = Caro; costo > 5x valor
- 3 = Moderadamente costoso; costo 2-5x valor
- 4 = Razonable; costo similar a valor
- 5 = Muy rentable; costo << valor (>10x ROI)

Ejemplo - Métrica de Escaneo:

✗ Métrica débil (C=1): "Evaluación manual de seguridad física de todos los centros de datos"
(Costo: €50K/mes; valor: €5K detectar 1 problema/año)

✓ Métrica fuerte (C=5): "Alertas automatizadas de configuración insegura de SIEM"
(Costo: €1K/mes licencia; valor: €100K evitar breach mensual)

4. MATRIZ DE INTEGRACIÓN GQM + PRAGMATIC

4.1 Flujo de Validación Completo

GOAL (Nivel Conceptual)
↓
QUESTION (Nivel Operacional)
↓
METRIC (Nivel Cuantitativo)
↓
PRAGMATIC EVALUATION (Nueve criterios)
↓
DECISION: ¿Métrica recomendada?

4.2 Tabla de Integración (Ejemplo: Gestión de Riesgos NIS2)

Elemento	Contenido	Validación PRAGMATIC
GOAL	"España cumple NIS2 medidas técnicas antes de Q1 2026"	Relevante=5, Significativo=5
Q1	"¿Qué medidas técnicas son obligatorias?"	Accionable=4
M1	Matriz 21 medidas NIS2 con status (doc)	P=3, R=5, A=5, G=5, M=5, Ac=5, T=3, I=5, C=5
Q2	"¿Cuál es el % de conformidad actual?"	Oportuno=4
M2	% medidas implementadas por categoría (0-100%)	P=5, R=5, A=5, G=4, M=5, Ac=4, T=5, I=4, C=5
Q3	"¿Cuál es la brecha por medida?"	Genuino=5
M3	Matriz de brechas (Objetivo - Actual) por medida	P=5, R=4, A=5, G=5, M=4, Ac=5, T=4, I=5, C=4
Q4	"¿Cuál es el riesgo residual?"	Predictivo=5
M4	AVRQ Score por medida no implementada (0-1.0)	P=5, R=5, A=5, G=5, M=5, Ac=5, T=4, I=3, C=3
Q5	"¿Podemos cumplir en tiempo?"	Accionable=4
M5	Roadmap con hitos Q1 2026 vs actual	P=4, R=5, A=5, G=5, M=5, Ac=5, T=5, I=4, C=5

4.3 Scoring PRAGMATIC Agregado

Fórmula:

$$\text{PRAGMATIC Score} = (P + R + A + G + M + Ac + T + I + C) / 9$$

Interpretación:

Score ≥ 4.5 = EXCEPCIONAL - Implementar sin dudas

Score 4.0-4.5 = EXCELENTE - Implementar

Score 3.5-4.0 = BUENO - Implementar con notas

Score 3.0-3.5 = ACEPTABLE - Considerar mejoras

Score < 3.0 = DÉBIL - Redefinir o descartar

Para Matriz arriba:

- M2 (% conformidad): PRAGMATIC Score = $(5+5+5+4+5+4+5+4+5)/9 = 4.67$ ✓ EXCEPCIONAL

- M4 (AVRQ): PRAGMATIC Score = $(5+5+5+5+5+5+4+3+3)/9 = 4.44$ ✓ EXCELENTE

5. APLICACIÓN A CIBERSEGURIDAD ESPAÑA (MERCURY AVRQ)

5.1 Árbol GQM Completo para Mercury

GOAL CORPORATIVO:

"Gestión cuantificada de riesgos cibernéticos alineada con NIS2 y maximización de ROI en inversiones de seguridad"

- GOAL TÁCTICO 1: Cuantificación de Riesgos en Moneda
 - Q1.1: ¿Cuál es el valor de nuestros activos críticos?
 - M1.1: Valuación de activos (USD/EUR)
 - Q1.2: ¿Cuál es la probabilidad de incidente?
 - M1.2: Threat frequency por tipo amenaza (%)
 - Q1.3: ¿Cuál es el impacto potencial?
 - M1.3: Loss magnitude por escenario (USD)
- GOAL TÁCTICO 2: Eficacia de Controles
 - Q2.1: ¿Qué controles tenemos activos?
 - M2.1: Inventario de controles (matriz)
 - Q2.2: ¿Qué tan efectivos son?
 - M2.2: Control efficacy score (0-100%)
 - Q2.3: ¿Cuál es la brecha?
 - M2.3: Gap = Target - Actual (%)
- GOAL TÁCTICO 3: Justificación de Inversión
 - Q3.1: ¿Cuál es el ROICS?
 - M3.1: $ROICS = (\text{Beneficios} - \text{Costo}) / \text{Costo} \times 100\%$
 - Q3.2: ¿Cuál es el payback period?
 - M3.2: $\text{Payback} = \text{Costo total} / \text{Beneficio anual}$
 - Q3.3: ¿Cuál es el riesgo residual?
 - M3.3: $\text{Riesgo Residual} = \text{Valor} \times \text{Prob} \times (1 - \text{Eficacia})$

5.2 Ejemplos de GQM + PRAGMATIC en Dominios Mercury

Dominio: Gestión de Vulnerabilidades

GOAL: Remediación rápida de vulnerabilidades para cumplir NIS2

Q1: ¿Qué vulnerabilidades tenemos detectadas?

— M1: # vulnerabilidades por CVSS score

— PRAGMATIC: P=5, R=4, A=3, G=5, M=4, Ac=3, T=5, I=5, C=5 → Score=4.33

Q2: ¿Cuál es el MTTR actual?

— M2: Tiempo promedio remediación por severidad (días)

— PRAGMATIC: P=5, R=5, A=5, G=5, M=5, Ac=5, T=5, I=4, C=5 → Score=4.78 ★

Q3: ¿Cumplimos SLA de remediación?

— M3: % vulnerabilidades críticas remediadas en <14 días

— PRAGMATIC: P=5, R=5, A=5, G=5, M=5, Ac=5, T=5, I=5, C=5 → Score=5.0 ★★

Dominio: Capacitación de Empleados

GOAL: Reducir riesgo humano mediante comportamiento seguro

Q1: ¿Cuál es el comportamiento actual de empleados?

- └ M1: % de click en phishing simulado
- └ PRAGMATIC: P=5, R=5, A=5, G=4, M=5, Ac=5, T=4, I=4, C=5 → Score=4.67

Q2: ¿Mejora el comportamiento post-training?

- └ M2: Reducción % click rate (antes/después)
- └ PRAGMATIC: P=5, R=5, A=5, G=5, M=4, Ac=5, T=5, I=3, C=5 → Score=4.67

Q3: ¿Cuál es el impacto en reducción de incidentes?

- └ M3: # incidentes originados en error humano
- └ PRAGMATIC: P=5, R=5, A=4, G=5, M=3, Ac=4, T=3, I=2, C=4 → Score=4.11

6. CICLO DE MEDICIÓN COMPLETO

6.1 Las 4 Fases

FASE 1: PLANEACIÓN (GQM Definition)

- └ Identificar stakeholders
- └ Definir GOAL corporativos
- └ Derivar preguntas operacionales
- └ Diseñar métricas
- └ Validar con PRAGMATIC (Score ≥ 3.5)

FASE 2: RECOLECCIÓN

- └ Implementar instrumentos de medición
- └ Automatizar recolección (si posible)
- └ Establecer baseline
- └ Auditar calidad de datos

FASE 3: ANÁLISIS

- └ Calcular valores de métricas
- └ Comparar vs. objetivos
- └ Identificar varianzas
- └ Generar insights

FASE 4: INTERPRETACIÓN Y ACCIÓN

- └ Comunicar resultados a stakeholders
- └ Tomar decisiones basadas en datos
- └ Implementar mejoras
- └ Re-baseline para ciclo siguiente

6.2 Cadencia Recomendada

Métricas PRAGMATIC Score ≥ 4.7 (P, R, A, Ac, T altos):

- Monitoreo SEMANAL (ej: % sistemas parchados)

Métricas PRAGMATIC Score 4.0-4.7:

- Monitoreo MENSUAL (ej: MTTR, MTTD)

Métricas PRAGMATIC Score 3.5-4.0:

- Monitoreo TRIMESTRAL (ej: Conformidad NIS2 global)

Métricas PRAGMATIC Score < 3.5 :

- Reconsiderar; si es necesaria: ANUAL (ej: Auditoría)

7. VALIDACIÓN Y EVOLUCIÓN DE MÉTRICAS

7.1 Criterios de Evolución

Una métrica debe revisarse si:

- x PRAGMATIC Score baja de 3.0
- x No predice resultados esperados ($P < 2$)
- x Ya no es relevante a stakeholders ($R < 2$)
- x Se ha vuelto trivial para actuar ($A < 2$)
- x Se ha vuelto fácil de manipular ($G < 2$)
- x Costo de recolección explota ($C < 2$)
- x Se obtiene demasiado tarde ($T < 2$)

7.2 Mejora Continua

Ciclo de Mejora GQM:

1. Recopilar feedback de usuarios de métrica
2. Validar PRAGMATIC criteria nuevamente
3. Si Score < 3.5 → Rediseñar
4. Si Score ≥ 3.5 pero feedback sugiere mejoras → Refinar
5. Implementar versión 2.0 de métrica
6. Re-baseline y comparar vs. versión anterior

CONCLUSIÓN

GQM + PRAGMATIC proporciona:

- ✓ Trazabilidad clara de objetivos a datos
- ✓ Validación de utilidad práctica de métricas
- ✓ Justificación de inversión en medición
- ✓ Evolución continua de marcos de medición
- ✓ Comunicación ejecutiva basada en hechos

Para Mercury específicamente:

- Garantiza que cada métrica es accionable ($A=5$)
- Asegura predictibilidad de riesgos ($P \geq 4$)
- Vincula a relevancia regulatoria ($R=5$ para NIS2)
- Autoprotege contra gaming ($G \geq 4$)

Fin del Marco GQM+ PRAGMATIC

Versión 2.0 | Enero 2026 | Basado en Basili (NASA) y Glasgow (PRAGMATIC Institute)